

CYBERSECURITY

GHI CHÚ HOÀN CHỈNH

≡ (AN NINH MẠNG) ≡



BẢO MẬT
MẠNG



ĐẠO ĐỨC
TIN TẮC



TƯỜNG LỬA
VÀ PHÒNG THỦ



PHÂN TÍCH
MÃ ĐỘC



BẢO VỆ
TRƯỚC MỐI ĐE DỌA

≡ TỪ CƠ BẢN ĐẾN NÂNG CAO ≡

VƯỢT SANG TRANG TIẾP THEO ➡

01. KIẾN THỨC CƠ BẢN VỀ AN NINH MẠNG

① An ninh mạng là gì?

An ninh mạng là việc bảo vệ hệ thống, mạng, ứng dụng và dữ liệu khỏi các truy cập, tấn công, hư hại hoặc gián đoạn trái phép.

Nó đảm bảo tính bảo mật, toàn vẹn và sẵn sàng của thông tin và hệ thống.

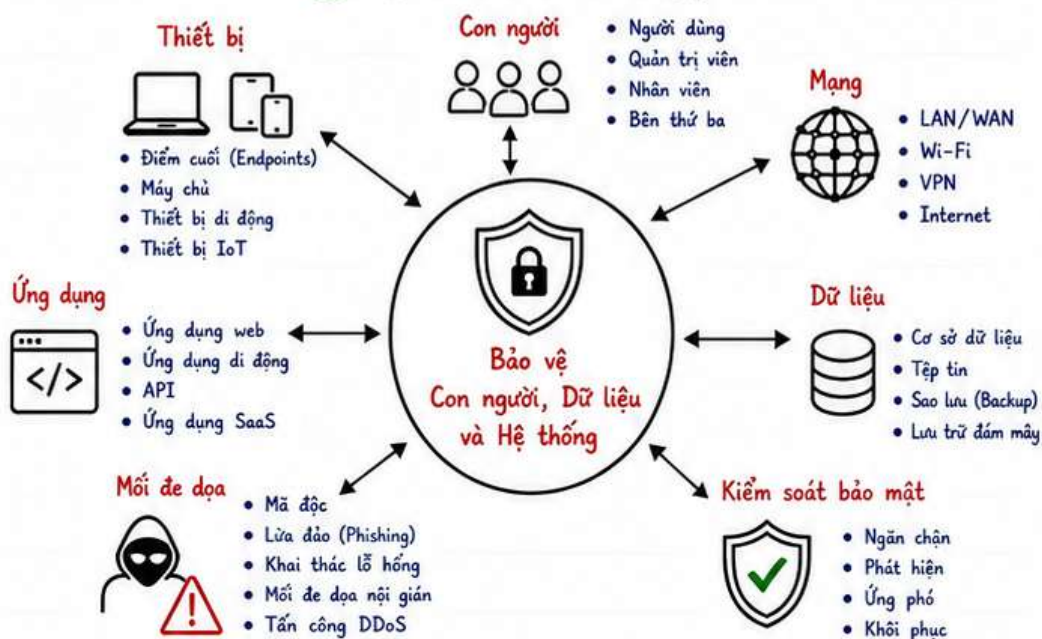
③ Tại sao an ninh mạng quan trọng?

- Bảo vệ **dữ liệu nhạy cảm** và quyền riêng tư
- Ngăn ngừa **tổn thất tài chính** và gian lận
- Đảm bảo hoạt động kinh doanh **liên tục** và đáng tin cậy
- Hỗ trợ **tuân thủ** pháp lý, quy định và các yêu cầu tuân thủ
- Bảo vệ **uy tín** và giá trị thương hiệu

② An ninh mạng vs An toàn thông tin

Khía cạnh	An ninh mạng	An toàn thông tin
Tập trung	Bảo vệ hệ thống, mạng và tài sản số	Bảo vệ mọi loại thông tin
Phạm vi	Công nghệ, mạng, ứng dụng, thiết bị	Con người, quy trình và công nghệ
Mối đe dọa	Tin tặc, mã độc, DDoS, lừa đảo, khai thác lỗ hổng	Rò rỉ nội bộ, rò rỉ thông tin, mối đe dọa vật lý
Mục tiêu	Ngăn chặn tấn công mạng và xâm phạm hệ thống	Bảo vệ thông tin dưới mọi hình thức

④ Hệ sinh thái an ninh mạng



⑤ Bức tranh mối đe dọa

- **Tác nhân nhà nước**
Đe dọa nâng cao, gián điệp, chiến tranh mạng.
- **Tội phạm mạng**
Lợi nhuận tài chính, tổng tiền, đánh cắp dữ liệu.
- **Tin tặc hoạt động vì mục đích chính trị**
Động cơ tư tưởng, phá hoại trang web, tấn công DDoS.
- **Nội gián**
Nhân viên cố ý hoặc vô tình gây hại.
- **Kẻ tấn công kịch bản**
Kẻ tấn công ít kỹ năng sử dụng công cụ có sẵn.

⑥ Bề mặt tấn công

Tổng số điểm mà kẻ tấn công trái phép có thể xâm nhập hoặc khai thác dữ liệu.

Bao gồm:

- Cổng mở, dịch vụ, API
- Ứng dụng web
- Tài khoản người dùng và quyền truy cập
- Thiết bị, điểm cuối, tài nguyên đám mây
- Tích hợp của bên thứ ba

⑦ Các biện pháp kiểm soát bảo mật cơ bản

- 🔒 **Ngăn chặn** – Tường lửa, kiểm soát truy cập, mã hóa, cập nhật bản vá
- 👁️ **Phát hiện** – IDS/IPS, giám sát, nhật ký, tình báo mối đe dọa
- 🔔 **Ứng phó** – Kế hoạch ứng phó sự cố, cảnh báo, khoanh vùng
- 🔄 **Khôi phục** – Sao lưu, khôi phục thảm họa, duy trì hoạt động

Ghi nhớ ☆

An ninh mạng không phải là một sản phẩm, mà là một quá trình.
Con người + Quy trình + Công nghệ
= An ninh mạnh mẽ

Sai lầm thường gặp ⚠️

Nghĩ rằng an ninh mạng chỉ là việc của đội IT.
Thực tế: Mọi người đều có trách nhiệm đối với an ninh.

💡 Mẹo phòng vấn

Giải thích Bộ ba CIA, các loại mối đe dọa, bề mặt tấn công và các biện pháp kiểm soát bảo mật bằng ví dụ cụ thể.

02. BỘ BA CIA & NGUYÊN TẮC AN NINH

① BỘ BA CIA LÀ GÌ?

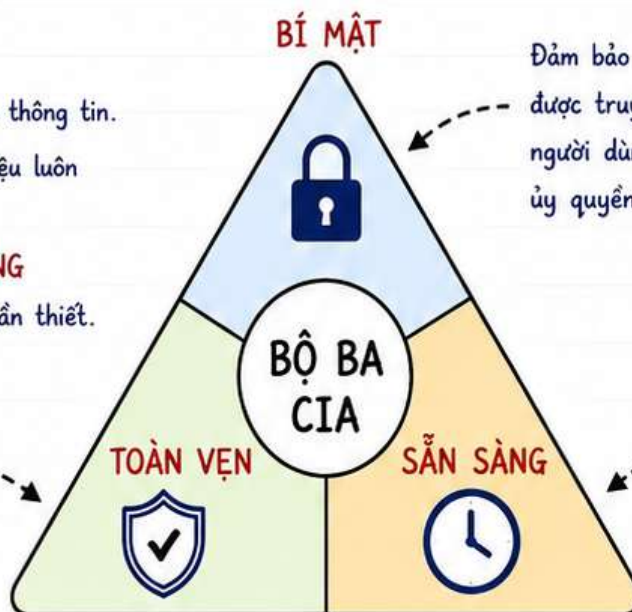
Bộ ba CIA là nền tảng của An toàn thông tin.

Nó đảm bảo rằng hệ thống và dữ liệu luôn được bảo vệ theo 3 yếu tố:

BÍ MẬT, TOÀN VỆ và SẴN SÀNG

cho người dùng được ủy quyền khi cần thiết.

Đảm bảo dữ liệu chính xác, đầy đủ và không bị thay đổi bởi người không được ủy quyền.



Đảm bảo dữ liệu chỉ được truy cập bởi người dùng được ủy quyền.

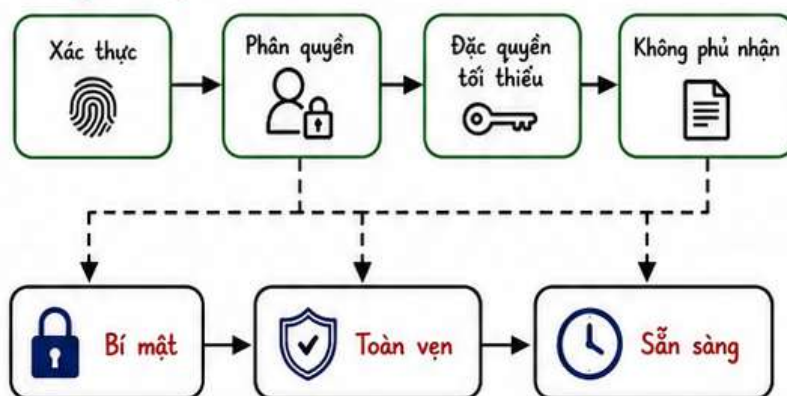
Đảm bảo hệ thống và dữ liệu luôn sẵn sàng khi người dùng được ủy quyền cần sử dụng.

② CÁC NGUYÊN TẮC AN NINH

	XÁC THỰC	Xác minh danh tính của người dùng hoặc hệ thống.
	PHÂN QUYỀN	Xác định người dùng đã xác thực được phép truy cập những gì.
	KHÔNG PHỦ NHẬN	Đảm bảo các hành động có thể truy vết và không thể chối bỏ sau này.
	ĐẶC QUYỀN TỐI THIỂU	Người dùng và hệ thống chỉ được cấp mức truy cập tối thiểu cần thiết để thực hiện nhiệm vụ.

③ CHÚNG HOẠT ĐỘNG CÙNG NHAU NHƯ THẾ NÀO?

An ninh không chỉ dựa vào một yếu tố riêng lẻ, mà là sự kết hợp của tất cả các nguyên tắc để bảo vệ **dữ liệu, hệ thống và người dùng**.



④ VÌ SAO CÁC NGUYÊN TẮC NÀY QUAN TRỌNG?

- Bảo vệ **dữ liệu nhạy cảm** tránh truy cập hoặc rò rỉ trái phép.
- Ngăn chặn **giả mạo dữ liệu** và duy trì sự tin cậy.
- Đảm bảo hệ thống hoạt động liên tục và ổn định.
- Hỗ trợ **tuân thủ** các quy định và yêu cầu pháp lý.
- Xây dựng **niềm tin** của người dùng và uy tín tổ chức.



LƯU Ý QUAN TRỌNG

Không có hệ thống nào an toàn 100%, nhưng việc tuân thủ các nguyên tắc này sẽ **giảm thiểu đáng kể** rủi ro và tác động của các cuộc tấn công.



GHI NHỚ

Bộ ba CIA bảo vệ **WHAT** (điều gì), các nguyên tắc an ninh bảo vệ **HOW** (như thế nào).



SAI LẦM THƯỜNG GẶP

Cấp nhiều quyền hơn cần thiết hoặc không thực thi nguyên tắc đặc quyền tối thiểu.



MẸO PHÒNG VẤN

Luôn liên hệ Bộ ba CIA và các nguyên tắc an ninh trong câu trả lời của bạn kèm ví dụ cụ thể.

03. KIẾN THỨC CƠ BẢN VỀ MẠNG ĐỂ ĐẢM BẢO AN NINH

3

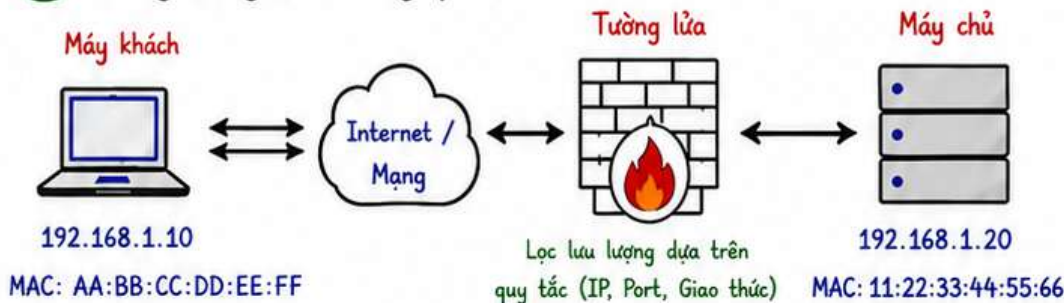
① Các khái niệm quan trọng

- Địa chỉ IP** (Logical Address): Xác định một thiết bị trên mạng.
 - IPv4 (32-bit) ví dụ: 192.168.1.10, IPv6 (128-bit)
- Địa chỉ MAC** (Physical Address): Địa chỉ phần cứng duy nhất gán cho giao diện mạng.
 - Ví dụ: 00:1A:2B:3C:4D:5E
- Cổng (Port)**: Các điểm cuối logic được giao thức sử dụng để xác định ứng dụng/dịch vụ.
Phạm vi: 0 - 65535
- DNS** (Domain Name System): Chuyển đổi tên miền (ví dụ: google.com) thành địa chỉ IP.
- HTTP và HTTPS**: HTTP không mã hóa (cổng 80). HTTPS được mã hóa bằng TLS/SSL (cổng 443).

Một số cổng (Port) phổ biến

Cổng (Port)	Dịch vụ
21	FTP
22	SSH
23	Telnet (Không an toàn)
53	DNS
80	HTTP
443	HTTPS
3306	MySQL
3389	RDP

② Luồng mạng (Mức tổng quan)



Ví dụ kết nối

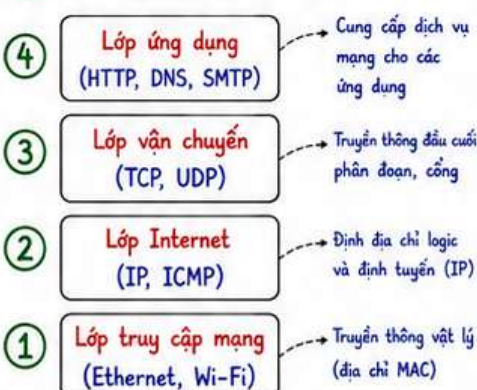
Máy khách truy cập
<https://example.com>
(cổng 443)

- DNS phân giải tên miền
- Thiết lập kết nối TCP
- Bắt tay TLS (HTTPS)
- Trao đổi dữ liệu an toàn

③ TCP vs UDP

Đặc điểm	TCP	UDP
Kiểu kết nối	Hướng kết nối (Connection-Oriented)	Không hướng kết nối (Connectionless)
Độ tin cậy	Đáng tin cậy (ACK, truyền lại)	Không đáng tin cậy
Tốc độ	Chậm hơn	Nhanh hơn
Ứng dụng	Web, Email, Truyền tệp, SSH, HTTPS	DNS, VoIP, Stream, Game online
Kích thước Header	20 - 60 bytes	8 bytes

④ Các lớp TCP/IP (4 lớp)



⑤ Vì sao kiến thức mạng quan trọng?

- ✓ Giúp hiểu cách các cuộc tấn công di chuyển trong mạng.
- ✓ Cần thiết để cấu hình tường lửa, IDS/IPS và phân đoạn mạng.
- ✓ Hỗ trợ xử lý sự cố an ninh.
- ✓ Cần cho kiểm thử xâm nhập và ứng cứu sự cố.
- ✓ Giúp cấu hình ứng dụng và dịch vụ an toàn.

☆ Ghi nhớ

IP = Vị trí thiết bị
MAC = Danh tính thiết bị
Port = Dịch vụ
TCP = Đáng tin cậy
UDP = Nhanh

⚠ Sai lầm thường gặp

Mở quá nhiều cổng không cần thiết trên tường lửa sẽ làm tăng nguy cơ bị tấn công.

🎯 Mẹo phỏng vấn

Nắm rõ các cổng phổ biến, sự khác nhau giữa TCP và UDP và vai trò của DNS, HTTP & HTTPS.

💡 Ví dụ nhanh

Mạng giống như một thành phố:
IP = Địa chỉ
Port = Phòng ban (departments)
Giao thức = Quy tắc giao tiếp

04. MỐI ĐE DỌA, LỖ HỔNG & RỦI RO

1 Các thuật ngữ quan trọng

- Mối đe dọa:** Bất kỳ điều gì có khả năng gây hại cho hệ thống, dữ liệu hoặc người dùng.
- Lỗ hổng:** Điểm yếu hoặc khuyết điểm có thể bị kẻ tấn công khai thác.
- Khai thác (Exploit):** Kỹ thuật hoặc mã được sử dụng để tận dụng lỗ hổng.
- Tác động:** Thiệt hại hoặc ảnh hưởng đến tính bảo mật, toàn vẹn hoặc sẵn sàng.
- Rủi ro:** Khả năng mối đe dọa sẽ khai thác lỗ hổng và gây ra tác động.
- Tác nhân đe dọa:** Cá nhân, nhóm hoặc tổ chức khởi xướng các mối đe dọa.

2 Các khái niệm tấn công

Vector tấn công

Con đường hoặc phương thức mà kẻ tấn công sử dụng để thực hiện tấn công.



Email



Web



USB



Mạng



Đám mây



Mạng xã hội

Bề mặt tấn công

Tổng số điểm có thể truy cập vào hệ thống mà người dùng không được ủy quyền có thể cố gắng tiếp cận.



Ứng dụng



Cơ sở dữ liệu



Máy chủ



API



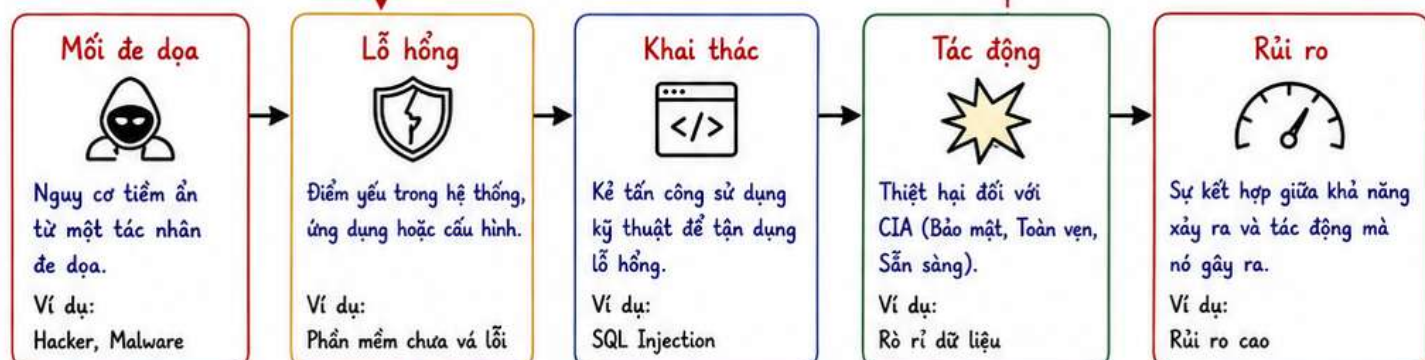
Tài khoản người dùng



Dịch vụ đám mây

3 Chuỗi rủi ro

Cải thiện các biện pháp kiểm soát để phá vỡ chuỗi



4 Các tác nhân đe dọa



- Tội phạm mạng:** Tìm kiếm lợi ích tài chính thông qua trộm cắp, lừa đảo, ransomware, v.v.



- Hacker hoạt động vì mục đích:** Được thúc đẩy bởi ý thức hệ hoặc chương trình nghị sự chính trị.



- Tác nhân nhà nước:** Thực hiện gián điệp, phá hoại hoặc chiến tranh mạng.



- Mối đe dọa nội bộ:** Nhân viên hoặc người dùng được ủy quyền cố ý hoặc vô ý lạm dụng quyền truy cập.



- Kẻ tấn công bằng kịch bản (Script Kiddies):** Kẻ tấn công ít kinh nghiệm sử dụng công cụ và mã khai thác có sẵn.

5 Công thức tính rủi ro

$$\text{Rủi ro} = \text{Khả năng xảy ra} \times \text{Tác động}$$

- Khả năng của mối đe dọa
- Khả năng khai thác lỗ hổng
- Mức độ phơi bày (Bề mặt tấn công)

- Mất tính bảo mật
- Mất tính toàn vẹn
- Gián đoạn hệ thống
- Tác động tài chính / pháp lý
- Thiệt hại uy tín

⚠ Lưu ý quan trọng

An ninh mạng là tất cả về việc giảm thiểu Rủi ro bằng cách giảm Lỗ hổng, thu hẹp Bề mặt tấn công và tăng cường Kiểm soát.

★ Ghi nhớ

- Bạn không thể loại bỏ hoàn toàn rủi ro.
- Bạn chỉ có thể giảm thiểu rủi ro.
- Tập trung vào những điều quan trọng nhất.

💡 Mẹo phỏng vấn

Luôn suy nghĩ: Điều gì có thể xảy ra sai?
Điểm yếu nằm ở đâu?
Tác động là gì?
Khả năng nó xảy ra là bao nhiêu?

05. CÁC CUỘC TẤN CÔNG MẠNG PHỔ BIẾN

① Tấn công mạng là gì?

Tấn công mạng là những hành động độc hại nhằm truy cập, đánh cắp, thay đổi, vô hiệu hóa hoặc phá hủy hệ thống, mạng hoặc dữ liệu.

② Phân loại tấn công (Cấp cao)

CÁC CUỘC TẤN CÔNG MẠNG

① Mã độc



Phần mềm độc hại được thiết kế để gây hại, làm gián đoạn hoặc chiếm quyền truy cập trái phép.

Mục tiêu:

Gây gián đoạn, phá hủy, đánh cắp dữ liệu.

② Virus



Tự gắn vào các tệp, chương trình và lan truyền khi được thực thi.

Mục tiêu:

Làm hỏng tệp tin, gây mất ổn định hệ thống.

③ Sâu máy (Worm)



Tự sao chép và lan truyền qua mạng mà không cần sự tương tác của người dùng.

Mục tiêu:

Tiêu tốn tài nguyên, làm gián đoạn mạng.

④ Trojan



Ẩn dưới dạng phần mềm hợp pháp nhưng thực hiện các hành động độc hại.

Mục tiêu:

Đánh cắp dữ liệu, tạo cửa hậu, do thám.

⑤ Ransomware



Mã hóa tệp/dữ liệu và yêu cầu tiền chuộc để khôi phục quyền truy cập.

Mục tiêu:

Thu lợi bất chính, tống tiền, đánh cắp dữ liệu.

⑥ Phishing



Giả mạo email/website để đánh lừa người dùng tiết lộ thông tin nhạy cảm.

Mục tiêu:

Đánh cắp thông tin đăng nhập, lừa đảo tài chính.

⑦ Kỹ thuật xã hội



Tác động tâm lý để lừa dối người dùng nhằm lấy thông tin hoặc quyền truy cập.

Mục tiêu:

Vượt qua bảo mật, khai thác con người.

⑧ Tấn công vét cạn



Thử nhiều mật khẩu hoặc khóa cho đến khi tìm được đúng.

Mục tiêu:

Giành quyền truy cập trái phép.

⑨ Tấn công bằng thông tin đăng nhập



Sử dụng thông tin đăng nhập bị rò rỉ hoặc đoán để truy cập tài khoản (ví dụ: nhồi thông tin đăng nhập).

Mục tiêu:

Chiếm đoạt tài khoản, đánh cắp dữ liệu.

⑩ Tấn công DoS / DDoS



Làm quá tải hệ thống hoặc mạng bằng lượng truy cập hoặc yêu cầu khổng lồ.

Mục tiêu:

Làm gián đoạn dịch vụ, khiến hệ thống không sẵn sàng.

★ Lưu ý quan trọng

Kẻ tấn công có thể kết hợp nhiều hình thức tấn công khác nhau trong cùng một chiến dịch.

Ví dụ: Email lừa đảo → Phát tán mã độc → Thực thi ransomware

🛡️ Thực hành tốt nhất

- ✓ Cập nhật hệ thống và ứng dụng thường xuyên
- ✓ Sử dụng mật khẩu mạnh và xác thực đa yếu tố (MFA)
- ✓ Đào tạo nhận thức cho người dùng
- ✓ Sao lưu dữ liệu định kỳ
- ✓ Triển khai phòng thủ nhiều lớp

☆ Ghi nhớ

Xác định → Phát hiện → Ngăn chặn
→ Ứng phó → Khôi phục
(Vòng đời bảo mật)

⚠️ Sai lầm thường gặp

Người dùng nhấp vào liên kết hoặc tải tệp đính kèm không rõ nguồn gốc từ các nguồn không đáng tin cậy.

🎯 Mẹo phòng vấn

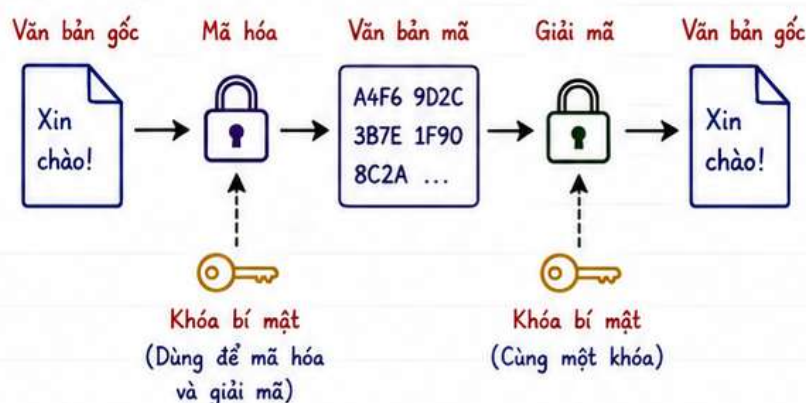
Hiểu mục đích, tác động và biện pháp phòng tránh cho từng loại tấn công với ví dụ thực tế.

06. KIẾN THỨC CƠ BẢN VỀ MẬT MÃ HỌC

① Các khái niệm cốt lõi

- **Mã hóa:** Chuyển đổi dữ liệu có thể đọc được (Văn bản gốc) thành dữ liệu không thể đọc được (Văn bản mã) bằng một khóa.
- **Mã hóa ký tự:** Chuyển đổi dữ liệu từ định dạng này sang định dạng khác (ví dụ: Base64) - KHÔNG nhằm mục đích bảo mật.
- **Hàm băm:** Chuyển đổi dữ liệu thành đầu ra có độ dài cố định (giá trị băm). Đây là một chiều, không thể đảo ngược.

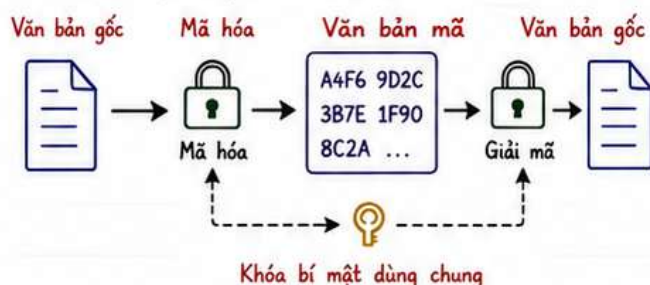
② Luồng cơ bản của mã hóa



③ Các loại mật mã

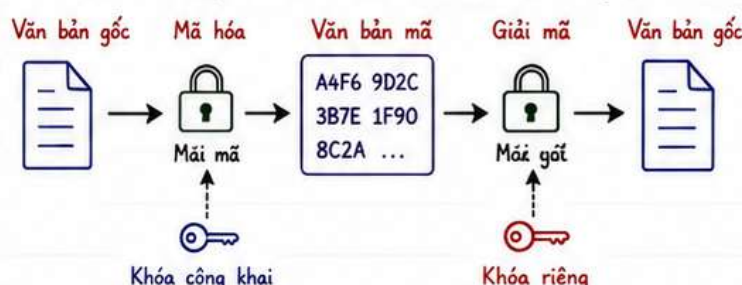
(A) Mã hóa đối xứng (Dùng khóa chung)

- Cùng một khóa được dùng cho cả mã hóa và giải mã.
- Nhanh, phù hợp với dữ liệu lớn.



(B) Mã hóa bất đối xứng (Dùng cặp khóa)

- Sử dụng một cặp khóa: Khóa công khai và khóa riêng.
- Khóa công khai để mã hóa, khóa riêng để giải mã.
- Chậm hơn, dùng cho trao đổi khóa an toàn và chữ ký số.



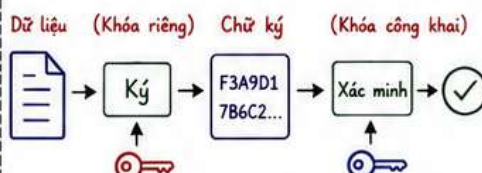
④ Các hàm băm

- Hàm một chiều. Dữ liệu gốc không thể khôi phục.
- Chỉ cần thay đổi rất nhỏ trong dữ liệu đầu vào sẽ tạo ra giá trị băm hoàn toàn khác.

Đầu vào	Băm (SHA-256)
Hello	185F8DB32271FE25...
hello	B6FC4C620B67D95F...
Hello!	7F355E862A9B1FFB...

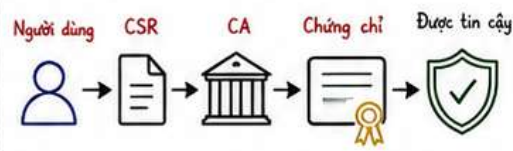
⑤ Chữ ký số

- Đảm bảo tính xác thực, toàn vẹn và không chối bỏ.
- Người ký dùng khóa riêng để ký.
- Người khác dùng khóa công khai để xác minh.



⑥ Những điều cơ bản về PKI

- PKI (Public Key Infrastructure) quản lý khóa và chứng chỉ số.
- Sử dụng các Cơ quan chứng thực (CA) để xác minh danh tính.



☆ Ghi nhớ

Mã hóa = Bảo mật
Mã hóa ký tự = Định dạng
Hàm băm = Toàn vẹn

⚠ Lưu ý quan trọng

Không bao giờ mã hóa khóa.
Sử dụng các thuật toán mạnh như
AES, RSA, SHA-256.

🎯 Thực hành tốt nhất

- ✓ Sử dụng TLS/SSL để truyền dữ liệu.
- ✓ Mã hóa dữ liệu nhạy cảm khi lưu trữ.
- ✓ Bảo vệ khóa riêng cẩn thận.
- ✓ Xoay vòng (thay đổi) khóa định kỳ.

💡 Mẹo phòng vấn

Hiểu sự khác nhau giữa Đối xứng và Bất đối xứng, Hàm băm, Chữ ký số và PKI.

07. Xác thực & Kiểm soát truy cập

① Các khái niệm chính

- Xác thực (Authentication):** Xác minh danh tính của người dùng hoặc hệ thống. (Bạn là ai?)
- Ủy quyền (Authorization):** Xác định người dùng đã xác thực được phép làm gì. (Bạn có thể truy cập gì?)
- Kiểm soát truy cập (Access Control):** Các chính sách và cơ chế thực thi quyết định ủy quyền.
- Mục tiêu:** Đảm bảo đúng người dùng có quyền truy cập đúng tài nguyên, đúng thời điểm, vì đúng lý do.

② Các phương pháp xác thực

	Một thứ bạn biết	Mật khẩu, PIN, câu hỏi bảo mật
	Một thứ bạn có	OTP, điện thoại, thẻ thông minh, khóa phần cứng
	Một thứ bạn là	Sinh trắc học: vân tay, khuôn mặt, mống mắt

★ Xác thực đa yếu tố (MFA)

Kết hợp từ hai yếu tố trở lên để xác minh danh tính.
Giảm đáng kể nguy cơ bị chiếm đoạt tài khoản.

③ Các mô hình kiểm soát truy cập

RBAC (Kiểm soát truy cập dựa trên vai trò)



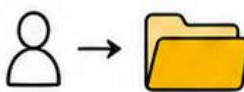
Quyền truy cập được cấp dựa trên vai trò của người dùng.
Ví dụ: Admin, Người dùng, Kiểm toán viên

ABAC (Kiểm soát truy cập dựa trên thuộc tính)



Quyền truy cập được cấp dựa trên thuộc tính và chính sách.
Ví dụ: Chỉ cho phép truy cập mạng nội bộ công ty trong giờ làm việc.

DAC (Kiểm soát truy cập dựa trên sự phân quyền)



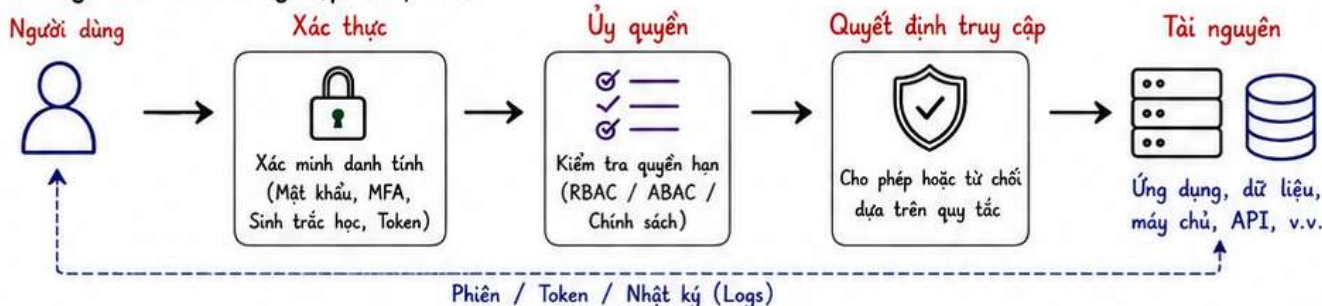
Chủ sở hữu tài nguyên quyết định ai được truy cập tài nguyên.
Ví dụ: Chủ sở hữu tệp cấp quyền cho người khác.

MAC (Kiểm soát truy cập bắt buộc)



Truy cập dựa trên nhãn bảo mật hoặc mức phân loại.
Sử dụng trong chính phủ, quân đội, hệ thống quan trọng.

④ Luồng kiểm soát truy cập (Cấp cao)



☆ Ghi nhớ

Xác thực = Xác minh danh tính
Ủy quyền = Kiểm tra quyền hạn
Kiểm soát truy cập = Thực thi quy tắc

⚠ Sai lầm thường gặp

Cấp quyền nhiều hơn mức cần thiết (Over-Privilege) là một rủi ro bảo mật lớn.

🎯 Thực hành tốt nhất

- ✓ Sử dụng MFA cho tất cả tài khoản
- ✓ Áp dụng nguyên tắc đặc quyền tối thiểu
- ✓ rà soát quyền truy cập thường xuyên
- ✓ Giám sát và kiểm toán truy cập

💡 Mẹo phỏng vấn

Luôn giải thích sự khác nhau giữa Xác thực và Ủy quyền với ví dụ thực tế.

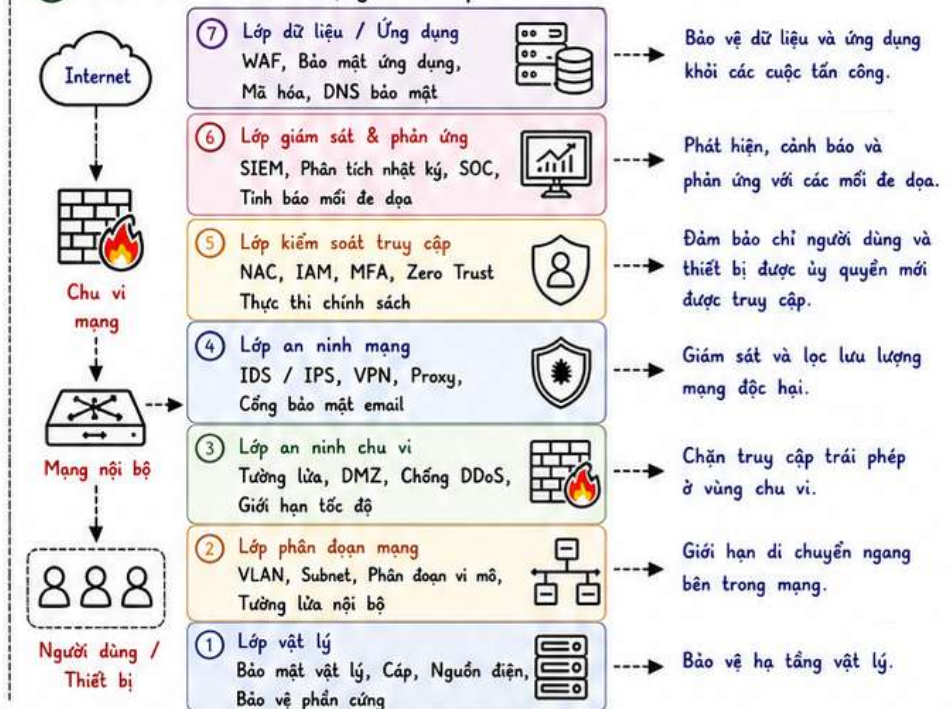
08. An ninh mạng

8

1 Các khái niệm chính

- Tường lửa (Firewall):** Kiểm soát lưu lượng mạng đi vào và đi ra.
- IDS:** Giám sát lưu lượng để phát hiện hoạt động đáng ngờ và tạo cảnh báo.
- IPS:** Chủ động chặn hoặc ngăn chặn lưu lượng độc hại.
- VPN:** Tạo đường hầm mã hóa qua mạng không đáng tin cậy.
- Proxy:** Làm trung gian giữa máy khách và máy chủ.
- NAC:** Đảm bảo chỉ các thiết bị đáng tin cậy, tuân thủ mới được truy cập mạng.
- Phân đoạn mạng:** Chia mạng thành các khu vực nhỏ hơn để giới hạn di chuyển.
- Phòng thủ nhiều lớp:** Sử dụng nhiều lớp kiểm soát bảo mật để giảm thiểu rủi ro.

2 Kiến trúc an ninh mạng theo lớp



3 Các thành phần bảo mật được giải thích

Tường lửa (Firewall) - Lọc lưu lượng dựa trên IP, cổng, giao thức. - Stateful / Next-Gen: kiểm tra sâu. - Loại: Packet Filter, Stateful, NGFW.	IDS (Hệ thống phát hiện xâm nhập) - Giám sát lưu lượng / nhật ký. - Phát hiện mẫu đáng ngờ. - Thụ động - chỉ cảnh báo. - Loại: NIDS, HIDS.	IPS (Hệ thống ngăn chặn xâm nhập) - Chủ động chặn mối đe dọa. - Kiểm tra lưu lượng nội tuyến. - Ngăn chặn tấn công theo thời gian thực. - Loại: NIPS, HIPS.	VPN (Mạng riêng ảo) - Tạo đường hầm mã hóa. - Đảm bảo tính bảo mật. - Loại: Truy cập từ xa, VPN site-to-site.	Proxy Server (Máy chủ proxy) - Làm trung gian giữa máy khách và máy chủ. - Ẩn mạng nội bộ. - Dùng để lưu đệm, lọc, kiểm soát truy cập.	NAC (Kiểm soát truy cập mạng) - Kiểm tra trạng thái thiết bị. - Thực thi tuân thủ trước khi cho truy cập. - Ví dụ: 802.1X, Cisco ISE, ClearPass.
--	--	---	---	--	--

4 Phân đoạn mạng



5 Phòng thủ nhiều lớp



☆ Ghi nhớ

Firewall = Kiểm soát truy cập
IDS = Phát hiện
IPS = Ngăn chặn
VPN = Bảo mật đường hầm
NAC = Tin cậy nhưng xác minh

⚠ Sai lầm thường gặp

- Chỉ dựa vào tường lửa.
- Phân đoạn mạng phảng (không phân đoạn).
- Bỏ qua các mối đe dọa nội bộ.

🎯 Thực hành tốt nhất

- ✓ Sử dụng bảo mật theo lớp.
- ✓ Cập nhật nhật ký và giám sát.
- ✓ Phân đoạn mạng đúng cách.
- ✓ Cập nhật và vá thiết bị thường xuyên.
- ✓ Áp dụng nguyên tắc đặc quyền tối thiểu.

💡 Mẹo phòng vấn

Luôn giải thích từng thành phần hoạt động như thế nào và chúng phối hợp với nhau. (Phòng thủ nhiều lớp)
Nếu có thể, hãy vẽ kiến trúc phân lớp.

09. An ninh ứng dụng web

① An ninh ứng dụng web là gì?

An ninh ứng dụng web bảo vệ các trang web và API web khỏi các cuộc tấn công khai thác lỗ hổng trong mã nguồn, thiết kế, logic hoặc cấu hình.

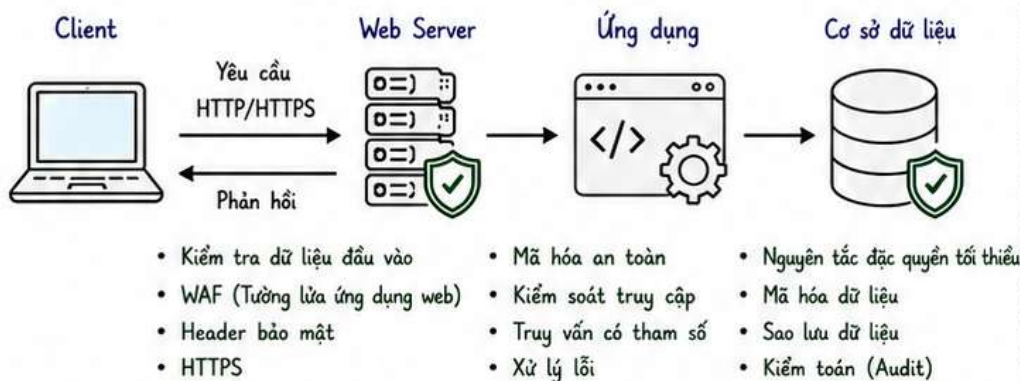
Mục tiêu:

Bảo vệ dữ liệu, duy trì tính toàn vẹn, đảm bảo sẵn sàng và duy trì niềm tin.

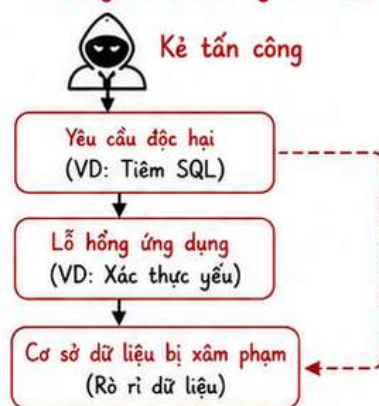
② 10 rủi ro hàng đầu theo OWASP (2021)

- | | |
|------------------------------|--|
| 1. Kiểm soát truy cập bị lỗi | 6. Các thành phần dễ bị tấn công và lỗi thời |
| 2. Lỗi mật mã | 7. Lỗi xác định danh tính và xác thực |
| 3. Tiêm lệnh | 8. Lỗi toàn vẹn dữ liệu và phần mềm |
| 4. Thiết kế không an toàn | 9. Lỗi ghi nhật ký và giám sát |
| 5. Cấu hình bảo mật sai | 10. Giả mạo yêu cầu phía máy chủ (SSRF) |

③ Luồng yêu cầu web → Ứng dụng → Cơ sở dữ liệu (Luồng tấn công / phòng thủ)



Đường đi tấn công (Ví dụ)



④ Các cuộc tấn công web phổ biến

Tiêm SQL <code>' OR 1=1 --</code> Kẻ tấn công chèn lệnh SQL để truy cập hoặc thao túng dữ liệu. Phòng ngừa: - Sử dụng truy vấn có tham số - Kiểm tra dữ liệu đầu vào	XSS (Cross-Site Scripting) <code><script>alert(1)</script></code> Kẻ tấn công chèn mã độc thực thi trên trình duyệt của người dùng. Phòng ngừa: - Mã hóa đầu ra - Chính sách bảo mật nội dung (CSP)	CSRF (Cross-Site Request Forgery) Buộc người dùng đã đăng nhập thực hiện hành động ngoài ý muốn. Phòng ngừa: - Token CSRF - Cookie SameSite	Kiểm soát truy cập bị lỗi Người dùng có thể truy cập hoặc sửa tài nguyên vượt quá quyền hạn. Phòng ngừa: - Thực thi ủy quyền - Đặc quyền tối thiểu	Cấu hình bảo mật sai Cấu hình mặc định không an toàn, mở cổng, hiển thị thông báo lỗi, v.v. Phòng ngừa: - Bảo mật cấu hình mặc định - Kiểm tra cấu hình định kỳ
---	--	---	--	---

⑤ Thực hành tốt nhất

- ✓ Xác thực tất cả dữ liệu đầu vào
- ✓ Áp dụng nguyên tắc đặc quyền tối thiểu
- ✓ Mã hóa dữ liệu khi truyền (TLS) và khi lưu trữ
- ✓ Luôn cập nhật thư viện và phần mềm
- ✓ Kiểm thử bảo mật thường xuyên

⚠ Sai lầm phổ biến

- Tin tưởng dữ liệu do người dùng gửi
- Hiển thị thông tin nhạy cảm trong thông báo lỗi
- Không mã hóa dữ liệu nhạy cảm
- Thiếu kiểm soát truy cập

★ Ghi nhớ

An toàn bằng thiết kế, an toàn theo mặc định, đặc quyền tối thiểu, phòng thủ theo nhiều lớp.

💡 Mẹo phòng vấn

Hãy sẵn sàng giải thích OWASP Top 10, Tiêm SQL, XSS, CSRF và cách bạn phòng ngừa chúng trong các dự án thực tế.

10. BẢO MẬT Đám MÂY

① Kiến thức cơ bản về bảo mật đám mây

- Bảo mật đám mây là hoạt động bảo vệ dữ liệu, ứng dụng, workload và hạ tầng trong môi trường đám mây.

- Bao gồm con người, quy trình, công nghệ chính sách.



Bảo vệ đám mây

- Mục tiêu: đảm bảo tính bí mật, tính toàn vẹn, để bạn có thể tập trung vào đối mỗi sáng tạo. tính sẵn sàng và tuân thủ trên môi trường Cloud.

② Mô hình trách nhiệm chia sẻ

On-Premises (Doanh nghiệp tự quản lý toàn bộ)	IaaS (Trách nhiệm chia sẻ)	SaaS (Nhà cung cấp quản lý nhiều hơn)
Dữ liệu	Dữ liệu	Dữ liệu
Ứng dụng	Ứng dụng	Ứng dụng
Runtime (Môi trường chạy)	Runtime (Môi trường chạy)	Runtime (Môi trường chạy)
Middleware (Phần mềm trung gian)	Middleware (Phần mềm trung gian)	Middleware (Phần mềm trung gian)
Hệ điều hành (OS)	Hệ điều hành (OS)	Hệ điều hành (OS)
Ảo hóa (Virtualization)	Ảo hóa (Virtualization)	Ảo hóa (Virtualization)
Máy chủ (Servers)	Máy chủ (Servers)	Máy chủ (Servers)
Lưu trữ (Storage)	Lưu trữ (Storage)	Lưu trữ (Storage)
Mạng (Networking)	Mạng (Networking)	Mạng (Networking)

☐ Bạn quản lý
☐ Nhà cung cấp Cloud quản lý

Kiểm soát nhiều hơn = Trách nhiệm nhiều hơn
 Thuận tiện nhiều hơn = Phụ thuộc nhà cung cấp nhiều hơn

③ Cloud IAM - Quản lý danh tính & truy cập



- Quản lý tập trung danh tính, vai trò và quyền hạn.
- Sử dụng RBAC / ABAC, Least Privilege và MFA.
- Thường xuyên giám sát và kiểm toán quyền truy cập.

④ Bảo mật lưu trữ



- Mã hóa dữ liệu khi lưu trữ.
- Sử dụng bucket và chính sách bảo mật.
- Kiểm soát quyền truy cập công khai.
- Phiên bản hóa và sao lưu.
- Bật ghi nhật ký.

⑤ Quản lý thông tin bí mật



- Lưu secret trong các vault (ví dụ: AWS Secrets Manager, Azure Key Vault, GCP Secret Manager).
- Thay đổi/luân chuyển secret định kỳ.
- Không hard-code secret vào mã nguồn.

⑥ Rủi ro do cấu hình sai



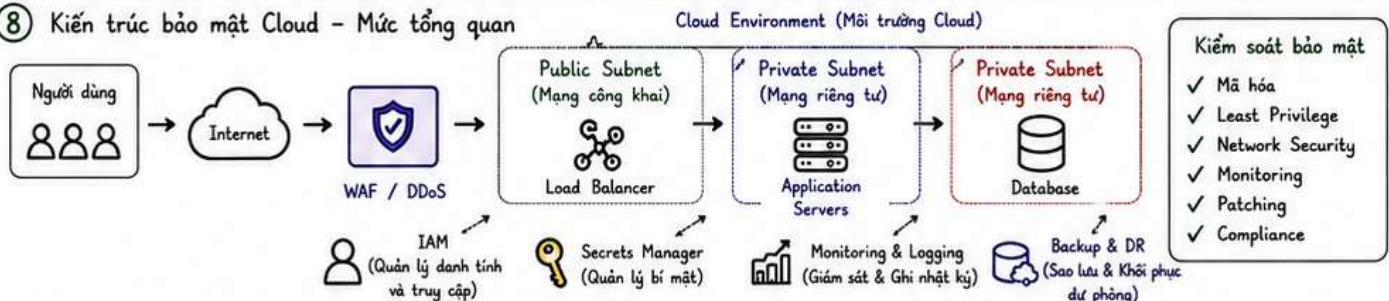
- Storage Bucket để công khai.
 - Chính sách IAM cấp quyền quá rộng.
 - Cơ sở dữ liệu công khai.
 - Dữ liệu không được mã hóa.
 - Tài khoản mặc định.
 - Dịch vụ không sử dụng vẫn được bật.
- Luôn tuân thủ các tiêu chuẩn cấu hình bảo mật.**

⑦ Bảo mật Container cơ bản



- Quét Container Image để tìm lỗ hổng.
- Sử dụng Base Image tối giản.
- Không chạy Container bằng tài khoản root.
- Sử dụng Image Signing.
- Áp dụng chính sách mạng.
- Bảo mật hệ thống điều phối như Kubernetes.

⑧ Kiến trúc bảo mật Cloud - Mức tổng quan



☆ Ghi nhớ

Cloud chỉ chuyển dịch trách nhiệm, không loại bỏ trách nhiệm. Bảo mật Cloud là trách nhiệm chung giữa khách hàng và nhà cung cấp.

⚠ Sai lầm thường gặp

- Cho rằng nhà cung cấp Cloud bảo mật mọi thứ.
- Bỏ qua các lỗi cấu hình.

🎯 Thực hành tốt nhất

- ✓ Tuân thủ nguyên tắc Least Privilege
- ✓ Bật Logging & Monitoring
- ✓ Mã hóa dữ liệu khi truyền và khi lưu
- ✓ Kiểm toán và rà soát định kỳ

💡 Mẹo phòng vấn

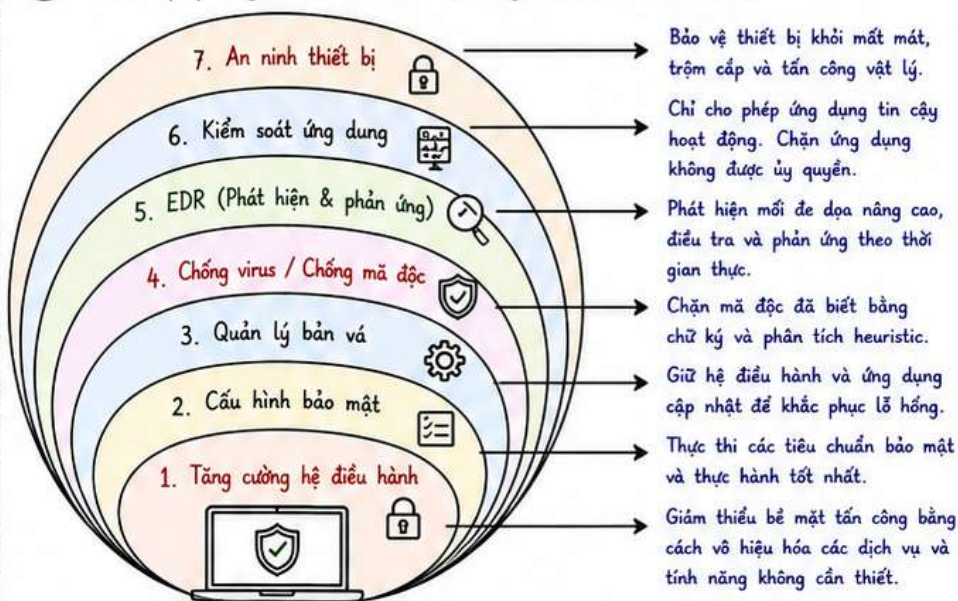
Nắm rõ Shared Responsibility Model và chuẩn bị các ví dụ thực tế về Cloud Misconfiguration (lỗi cấu hình Cloud).

11. An ninh điểm cuối & Hệ thống

① Các khái niệm chính

- **An ninh điểm cuối:** Bảo vệ các thiết bị như laptop, máy tính để bàn, máy chủ, điện thoại di động và thiết bị IoT.
- **Mục tiêu:** Ngăn chặn, phát hiện và phản ứng với các mối đe dọa nhắm vào điểm cuối.
- An ninh điểm cuối mạnh giúp giảm thiểu rủi ro từ mã độc, đánh cắp dữ liệu và truy cập trái phép.

② Các lớp phòng thủ điểm cuối (Phòng thủ theo chiều sâu)



③ Các thành phần chính được giải thích

1. Tăng cường hệ điều hành Bảo vệ hệ điều hành bằng cách vô hiệu hóa dịch vụ không dùng, thay đổi cấu hình mặc định và thực thi chính sách mạnh. Ví dụ: • Vô hiệu hóa tài khoản Guest • Chính sách mật khẩu mạnh • Bật tường lửa	2. Cấu hình bảo mật Áp dụng các tiêu chuẩn bảo mật và cấu hình theo chuẩn. Ví dụ: • Chuẩn CIS Benchmarks • Chính sách nhóm • Kiểm toán hệ thống	3. Quản lý bản vá Thường xuyên cập nhật hệ điều hành và phần mềm để khắc phục các lỗ hổng đã biết. Ví dụ: • Windows Update • WSUS • Công cụ và của bên thứ ba	4. Chống virus / Chống mã độc Phát hiện và chặn phần mềm độc hại, ransomware, trojan và các tệp độc hại khác. Ví dụ: • Windows Defender • Symantec • Kaspersky	5. EDR (Phát hiện & phản ứng) Giám sát hành vi điểm cuối, phát hiện mối đe dọa và kích hoạt phản ứng sự cố. Ví dụ: • Microsoft Defender for Endpoint • CrowdStrike • SentinelOne	6. Kiểm soát ứng dụng Chỉ cho phép ứng dụng tin cậy, chặn ứng dụng chưa được ủy quyền hoặc độc hại. Ví dụ: • AppLocker • Windows Defender Application Control • WDAC	7. An ninh thiết bị Bảo vệ thiết bị khỏi các mối đe dọa vật lý và truy cập trái phép. Ví dụ: • BitLocker • Khóa màn hình • Xóa dữ liệu từ xa
--	---	---	--	--	--	--

④ Thực hành tốt nhất

- ✓ Luôn cập nhật hệ điều hành, ứng dụng và driver.
- ✓ Sử dụng mật khẩu mạnh và bật MFA.
- ✓ Bật tường lửa và bảo vệ điểm cuối.
- ✓ Áp dụng nguyên tắc đặc quyền tối thiểu cho người dùng.
- ✓ Theo dõi nhật ký và cảnh báo liên tục.
- ✓ Sao lưu dữ liệu quan trọng thường xuyên.

⚠ Sai lầm thường gặp

- Bỏ qua các bản cập nhật hệ thống.
- Sử dụng cấu hình mặc định.
- Chạy với quyền quản trị viên.
- Tải và cài đặt phần mềm không rõ nguồn gốc.
- Không có sao lưu hoặc không ghi nhật ký.

💡 Mẹo phòng vấn

Nắm vững các lớp bảo mật điểm cuối và vai trò của từng lớp.
Sẵn sàng giải thích EDR và tầm quan trọng của Quản lý bản vá.
Ngoài ra, hiểu về tăng cường hệ điều hành và kiểm soát ứng dụng trong thực tế.

☆ Ghi nhớ

Cloud chỉ chuyển đổi trách nhiệm, không loại bỏ trách nhiệm.
Bảo mật là hành trình chung giữa khách hàng và nhà cung cấp.

Điểm cuối mạnh = Tư thế bảo mật vững chắc

Điểm cuối được bảo vệ giúp bảo vệ dữ liệu, người dùng và doanh nghiệp.

🎯 Kết luận chính

Bảo mật theo nhiều lớp ở điểm cuối đảm bảo phòng ngừa, phát hiện và phản ứng.

12. AN NINH EMAIL & KỸ THUẬT XÃ HỘI

① Các loại tấn công dựa trên Email



Phishing (Lừa đảo): Gửi hàng loạt email giả mạo đến nhiều người dùng để đánh cắp thông tin đăng nhập hoặc phát tán mã độc.



Spear Phishing (Lừa đảo có chủ đích): Tấn công vào một cá nhân cụ thể bằng cách sử dụng thông tin cá nhân hóa.



Whaling (Nhắm vào lãnh đạo cấp cao): Nhắm vào các lãnh đạo (CEO, CFO, ...) để lừa họ thực hiện hành động nhạy cảm.



BEC (Business Email Compromise - Chiếm đoạt email doanh nghiệp): Kẻ tấn công giả mạo người liên hệ tin cậy để đánh cắp tiền hoặc dữ liệu.

② Các bẫy thường gặp trong Email



Tệp đính kèm độc hại: Tệp chứa mã độc (exe, docm, zip, js, ...).



Liên kết độc hại: Liên kết đến trang web giả mạo để đánh cắp thông tin hoặc cài đặt mã độc.



Kỹ thuật xã hội (Social Engineering): Kẻ tấn công khai thác cảm xúc của con người – như sợ hãi, khẩn cấp, tò mò, tham lam hoặc lòng tin – để thao túng hành động.

③ Cấu trúc của một Email lừa đảo (Phishing)

Người gửi giả mạo

From: support@secure-login.com
To: victim@company.com
Subject: **Khẩn cấp: Xác minh tài khoản của bạn ngay!**

Lời chào chung chung

Kính gửi Quý khách hàng,

Tạo cảm giác khẩn cấp

Chúng tôi phát hiện hoạt động bất thường trên tài khoản của bạn.

Tài khoản của bạn sẽ bị tạm khóa trong 24 giờ tới nếu bạn không xác minh ngay.

Liên kết độc hại / Kêu gọi hành động

Vui lòng nhấp vào nút bên dưới để xác minh tài khoản của bạn.

Ngữ pháp / Chính tả kém

Cảm ơn,
Đội ngũ Hỗ trợ Tài khoản

Logo / Thương hiệu giả

Secure Login
© 2024 Secure Login. All rights reserved.



Dấu hiệu cảnh báo

- Địa chỉ người gửi lạ hoặc giống giả mạo
- Lời chào chung chung (ví dụ: "Kính gửi Quý khách hàng")
- Ngôn ngữ khẩn cấp / đe dọa Liên kết đáng ngờ (di chuột để kiểm tra URL)
- Tệp đính kèm không mong đợi
- Lỗi chính tả và ngữ pháp
- Yêu cầu thông tin nhạy cảm (mật khẩu, OTP, thông tin thẻ, ...)

④ Phòng ngừa & Thực hành tốt nhất

- ✓ Kiểm tra kỹ địa chỉ email của người gửi.
- ✓ Di chuột qua liên kết trước khi nhấp. Kiểm tra URL thực tế.
- ✓ Không mở tệp đính kèm không mong đợi.
- ✓ Không chia sẻ mật khẩu, OTP, PIN hoặc thông tin nhạy cảm.
- ✓ Báo cáo email đáng ngờ cho đội ngũ IT/An ninh thông tin.
- ✓ Bật xác thực đa yếu tố (MFA) cho tất cả tài khoản.
- ✓ Luôn nâng cao nhận thức bảo mật và cập nhật kiến thức.
- ✓ Sử dụng bộ lọc email, giải pháp chống phishing và sandbox.



Ghi nhớ

Kẻ tấn công không phá hệ thống, chúng đánh vào con người.
Hãy cảnh giác.
Suy nghĩ trước khi nhấp!

⑤ Các kỹ thuật của Kỹ thuật xã hội



Kẻ tấn công

- Giả vờ / Tạo tình huống (tạo câu chuyện)
- Mối như (đưa ra điều hấp dẫn)
- Quyền hạn (đưa ra thông tin/hỗ trợ)
- Tạo áp lực (theo dõi, gây áp lực an toàn)
- Giả mạo (giả danh người đáng tin cậy)



Nạn nhân

Vì sao hiệu quả?

- Tin tưởng & Thẩm quyền
- Sự khẩn cấp & Sợ hãi
- Tò mò & Lòng tham
- Sự hữu ích
- Thiếu nhận thức



Thực hành tốt nhất

- ✓ Xác minh trước khi tin tưởng.
- ✓ Sử dụng MFA ở mọi nơi.
- ✓ Giữ cho hệ thống & công cụ luôn cập nhật.
- ✓ Đào tạo người dùng thường xuyên.



Sai lầm thường gặp

- Nhấp vào liên kết mà không suy nghĩ.
- Bỏ qua các cảnh báo nhỏ.
- Chia sẻ thông tin quá dễ dàng.
- Giả định email là thật.



Bài học quan trọng

Email là một trong những vật vector tấn công mạnh nhất.
Nhận thức + Xác minh
= Phòng thủ vững chắc nhất.



Mẹo phòng vấn

Nắm rõ các loại tấn công qua Email, các dấu hiệu cảnh báo và cách bạn xử lý một tình huống phishing trong thực tế.

13. Quản lý lỗ hổng bảo mật

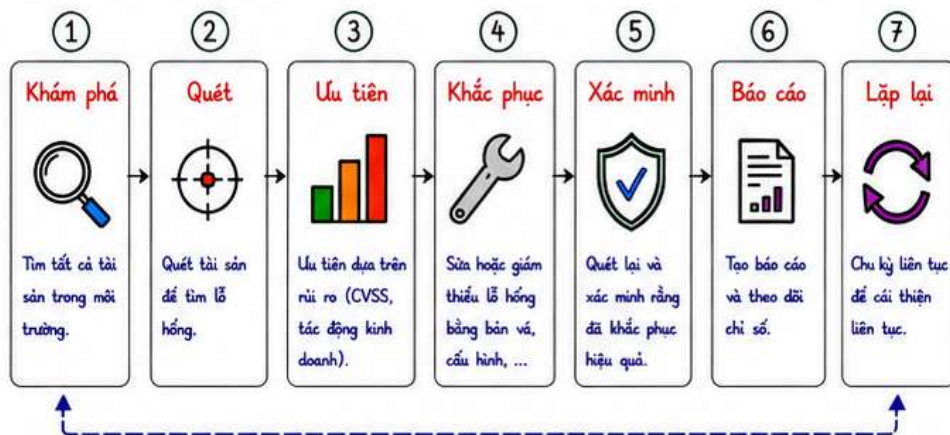
① Quản lý lỗ hổng bảo mật là gì?

Quản lý lỗ hổng bảo mật là quá trình liên tục nhận diện, đánh giá, ưu tiên, khắc phục và xác minh các lỗ hổng bảo mật trong hệ thống, ứng dụng và mạng.

Mục tiêu:

Giảm bề mặt tấn công và rủi ro bằng cách khắc phục các lỗ hổng trước khi kẻ tấn công khai thác.

② Vòng đời quản lý lỗ hổng



③ Các khái niệm quan trọng

- Tài sản (Asset)**: Bất kỳ thiết bị, ứng dụng, dịch vụ, tài nguyên đám mây, tài khoản người dùng, v.v.
- Lỗ hổng (Vulnerability)**: Điểm yếu có thể bị khai thác.
- CVE (Common Vulnerabilities and Exposures)**: Mã định danh duy nhất cho một lỗ hổng đã biết.
- CVSS (Common Vulnerability Scoring System)**: Hệ thống chấm điểm lỗ hổng (thang điểm 0.0 - 10.0) để đánh giá mức độ nghiêm trọng.
- Rủi ro (Risk)** = Khả năng khai thác × Tác động

④ Thang điểm CVSS (v3.1)

Khoảng điểm	Mức độ nghiêm trọng	Mô tả	Hành động
9.0 - 10.0	Nghiêm trọng	Rủi ro rất cao, dễ khai thác, tác động lớn	Khắc phục ngay
7.0 - 8.9	Cao	Rủi ro cao, tác động đáng kể	Khắc phục sớm
4.0 - 6.9	Trung bình	Rủi ro trung bình, tác động hạn chế	Khắc phục sớm
0.1 - 3.9	Thấp	Rủi ro thấp, tác động tối thiểu	Khắc phục khi có thể
0.0	Không có	Chỉ mang tính thông tin	Theo dõi

⑤ Các yếu tố ưu tiên rủi ro

- ✓ Điểm CVSS (Điểm cơ bản)
- ✓ Khả năng khai thác (Có khai thác được không?)
- ✓ Độ quan trọng của tài sản (Tác động kinh doanh)
- ✓ Mức độ phơi bày (Đối diện Internet hay nội bộ)
- ✓ Độ nhạy cảm của dữ liệu
- ✓ Các biện pháp kiểm soát bù trừ
- ✓ Tình báo về mối đe dọa (Threat Intelligence)

Rủi ro càng cao
=
Ưu tiên càng cao

⑥ Ví dụ khắc phục

Quản lý bản vá (Patch Management)

- Cập nhật hệ điều hành
- Cập nhật ứng dụng
- Cập nhật firmware
- Cập nhật phần mềm bên thứ ba



Sửa lỗi cấu hình (Configuration Fixes)

- Vô hiệu hóa các dịch vụ không cần thiết
- Sử dụng mật khẩu mặc định mạnh
- Mã hóa dữ liệu
- Áp dụng các tiêu chuẩn bảo mật



⑦ Các công cụ thường dùng



⑧ Quản lý lỗ hổng liên tục

- Lỗ hổng mới được phát hiện hàng ngày.
- Quét và giám sát liên tục giúp tổ chức luôn được bảo vệ.
- Tích hợp với SIEM / Ticketing / Patch Management để tự động hóa.



★ Thực hành tốt nhất

- ✓ Quét định kỳ (hàng tuần/hàng ngày)
- ✓ Ưu tiên dựa trên rủi ro
- ✓ Áp dụng bản vá kịp thời
- ✓ Xác minh và kiểm tra sau khi sửa lỗi
- ✓ Theo dõi chỉ số và cải thiện

⚠ Sai lầm thường gặp

- Quét nhưng không khắc phục.
- Bỏ qua các lỗ hổng mức thấp.
- Không ưu tiên theo rủi ro.
- Không xác minh sau khi sửa lỗi.
- Danh sách tài sản không đầy đủ.

🎯 Ghi nhớ

Bạn không thể bảo vệ những gì bạn không biết.
Khám phá → Quét → Sửa → Xác minh → Lặp lại

☀ Mẹo phòng vấn

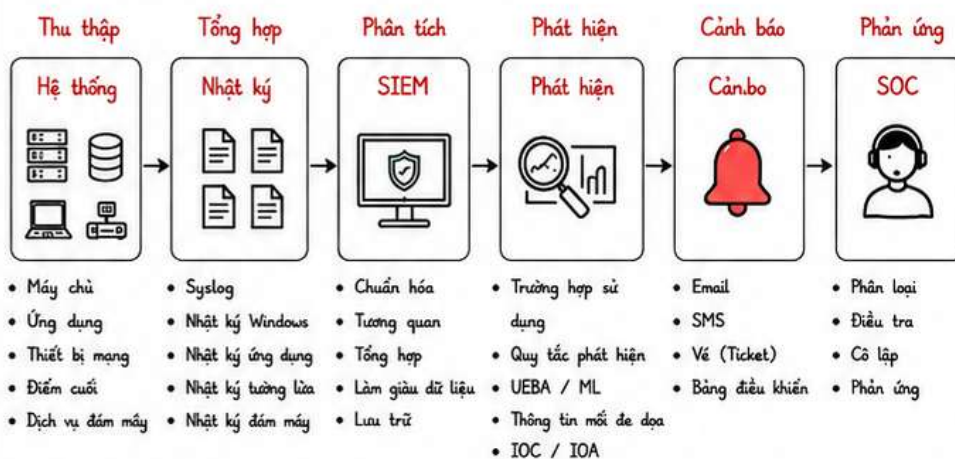
Hiểu rõ vòng đời quản lý lỗ hổng, thang điểm CVSS và cách bạn ưu tiên và khắc phục lỗ hổng trong các môi trường thực tế.

14. Giám sát bảo mật & SIEM

① Các khái niệm chính

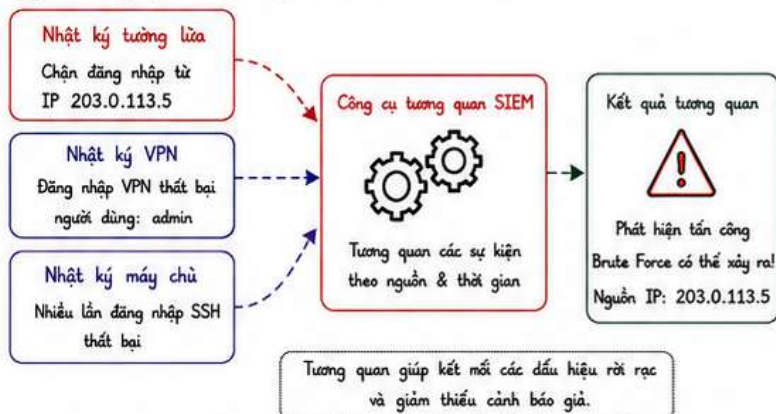
- Nhật ký (Logs):** Ghi lại các hoạt động được tạo ra bởi hệ thống, ứng dụng, thiết bị và người dùng.
- Sự kiện bảo mật (Security Events):** Các sự kiện cụ thể có liên quan đến bảo mật.
- Cảnh báo (Alerts):** Thông báo được tạo khi sự kiện phù hợp với quy tắc hoặc chỉ ra hoạt động đáng ngờ.
- SIEM (Security Information and Event Management):** Thu thập, tương quan và phân tích các sự kiện bảo mật theo thời gian thực.
- SOC (Security Operations Center):** Nhóm chuyên gia giám sát, điều tra và phản ứng với các mối đe dọa.

② Luồng giám sát (Monitoring Flow)



Mục tiêu: Phát hiện mối đe dọa sớm, điều tra nhanh và phản ứng hiệu quả.

③ Tương quan nhật ký (Ví dụ)



④ Quy tắc phát hiện (Ví dụ)

Nếu xảy ra...	Kích hoạt cảnh báo
Hơn 5 lần đăng nhập thất bại từ cùng một IP trong 5 phút	Cảnh báo tấn công Brute Force
Người dùng đăng nhập từ vị trí không thể đi lại được	Cảnh báo di chuyển không thể xảy ra
Phát hiện phần mềm độc hại trên điểm cuối	Cảnh báo phần mềm độc hại
Truyền dữ liệu lên ra IP bên ngoài	Cảnh báo rò rỉ dữ liệu
Tài khoản đặc quyền được sử dụng ngoài giờ làm việc	Cảnh báo lạm dụng đặc quyền

⑤ Thông tin mối đe dọa, IOC & IOA



Sử dụng Threat Intel + IOC/IOA trong SIEM để phát hiện và ngăn chặn mối đe dọa mỗi xuất hiện.

⑥ Lợi ích của SIEM

- ✓ Hiển thị tập trung toàn bộ môi trường.
- ✓ Phát hiện và cảnh báo mối đe dọa theo thời gian thực.
- ✓ Tương quan giúp giảm nhiễu và cảnh báo giả.
- ✓ Hỗ trợ tuân thủ và yêu cầu kiểm toán.
- ✓ Tăng tốc độ phản ứng sự cố.



☆ Thực hành tốt nhất

- ✓ Thu thập nhật ký liên quan từ tất cả các nguồn.
- ✓ Đồng bộ thời gian (NTP) trên toàn hệ thống.
- ✓ Thường xuyên tinh chỉnh và kiểm thử quy tắc.
- ✓ Áp dụng nguyên tắc đặc quyền tối thiểu cho quyền truy cập SIEM.
- ✓ Giám sát sức khỏe và lưu trữ của SIEM.

⚠ Sai lầm thường gặp

- Thu thập nhật ký không đủ.
- Bỏ qua một số cảnh báo.
- Không có tinh chỉnh hoặc rà soát quy tắc.
- Đồng bộ thời gian kém.
- Không sử dụng thông tin mối đe dọa.

🎯 Ghi nhớ

Bạn không thể bảo vệ những gì bạn không nhìn thấy.
Khám phá → Phát hiện → Phản ứng → Cải thiện

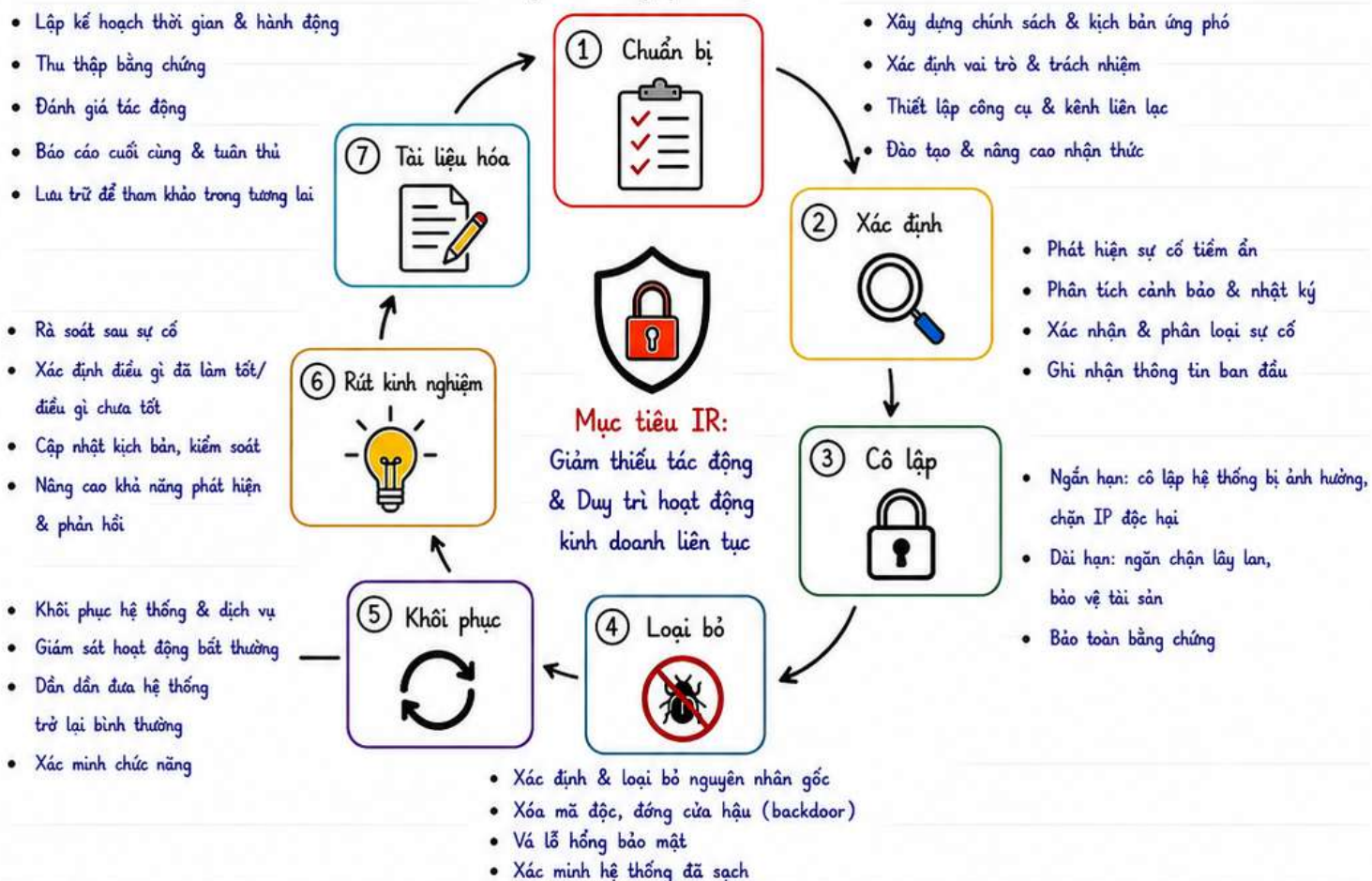
💡 Mẹo phòng vấn

Hiểu rõ nguồn nhật ký, tương quan, IOC và IOA, quy tắc phát hiện và cách SIEM hỗ trợ hoạt động của SOC.

15. ỨNG PHÓ SỰ CỐ

Ứng phó sự cố là cách tiếp cận có cấu trúc để phát hiện, phản hồi và khôi phục sau các sự cố bảo mật, nhằm giảm thiểu tác động và khôi phục hoạt động bình thường.

Vòng đời ứng phó sự cố



⚠️ Các loại sự cố phổ biến

- Mã độc (Malware / Ransomware)
- Lừa đảo (Phishing / BEC)
- Truy cập trái phép
- Rò rỉ dữ liệu
- Tấn công từ chối dịch vụ (DDoS)
- Mối đe dọa nội bộ



★ Nguyên tắc chính

- ✓ Hành động nhanh chóng
- ✓ Bảo toàn bằng chứng
- ✓ Giao tiếp rõ ràng
- ✓ Giảm thiểu tác động đến kinh doanh
- ✓ Tuân thủ quy trình & kịch bản
- ✓ Cải tiến liên tục



📋 Ghi chú quan trọng

- Tốc độ + Độ chính xác = Ứng phó hiệu quả
- Chuẩn bị tốt giúp giảm thời gian phản hồi
- Không bỏ qua việc tài liệu hóa
- Mỗi sự cố là một cơ hội để học hỏi

🛡️ Thực hành tốt nhất

- ✓ Cập nhật kịch bản IR thường xuyên
- ✓ Bật ghi nhật ký & giám sát
- ✓ Tổ chức diễn tập & mô phỏng định kỳ
- ✓ Sao lưu & kiểm thử khôi phục
- ✓ Hạn chế quyền truy cập đặc quyền

⚠️ Sai lầm thường gặp

- Phát hiện chậm trễ
- Giao tiếp kém
- Không bảo toàn bằng chứng
- Loại bỏ chưa triệt để
- Không rà soát sau sự cố

📌 Ghi nhớ

Chuẩn bị trước,
Phát hiện sớm,
Phản hồi nhanh,
Khôi phục an toàn,
Cải tiến liên tục.

☀️ Mẹo phỏng vấn

Hãy nêu từng giai đoạn trong quy trình ứng phó sự cố với ví dụ thực tế. Nhắc đến các công cụ như SIEM, EDR, SOAR và hệ thống Ticketing.

16. ỨNG PHÓ SỰ CỐ

Ứng phó sự cố là cách tiếp cận có cấu trúc để phát hiện, phản hồi và khôi phục sau các sự cố bảo mật, nhằm giảm thiểu tác động và khôi phục hoạt động bình thường.

Vòng đời ứng phó sự cố



⚠️ Các loại sự cố phổ biến

- Mã độc (Malware / Ransomware)
- Lừa đảo (Phishing / BEC)
- Truy cập trái phép
- Rò rỉ dữ liệu
- Tấn công từ chối dịch vụ (DDoS)
- Mối đe dọa nội bộ



★ Nguyên tắc chính

- Hành động nhanh chóng
- Bảo toàn bằng chứng
- Giao tiếp rõ ràng
- Giảm thiểu tác động đến kinh doanh
- Tuân thủ quy trình & kịch bản
- Cải tiến liên tục



📋 Ghi chú quan trọng

- Tốc độ + Độ chính xác = Ứng phó hiệu quả
- Chuẩn bị tốt giúp giảm thời gian phản hồi
- Không bỏ qua việc tài liệu hóa
- Mỗi sự cố là một cơ hội để học hỏi

🛡️ Thực hành tốt nhất

- Cập nhật kịch bản IR thường xuyên
- Bật ghi nhật ký & giám sát
- Tổ chức diễn tập & mô phỏng định kỳ
- Sao lưu & kiểm thử khôi phục
- Hạn chế quyền truy cập đặc quyền

⚠️ Sai lầm thường gặp

- Phát hiện chậm trễ
- Giao tiếp kém
- Không bảo toàn bằng chứng
- Loại bỏ chưa triệt để
- Không rà soát sau sự cố

📌 Ghi nhớ

Chuẩn bị trước,
Phát hiện sớm,
Phản hồi nhanh,
Khôi phục an toàn,
Cải tiến liên tục.

💡 Mẹo phỏng vấn

Hãy nêu từng giai đoạn trong quy trình ứng phó sự cố với ví dụ thực tế. Nhắc đến các công cụ như SIEM, EDR, SOAR và hệ thống Ticketing.

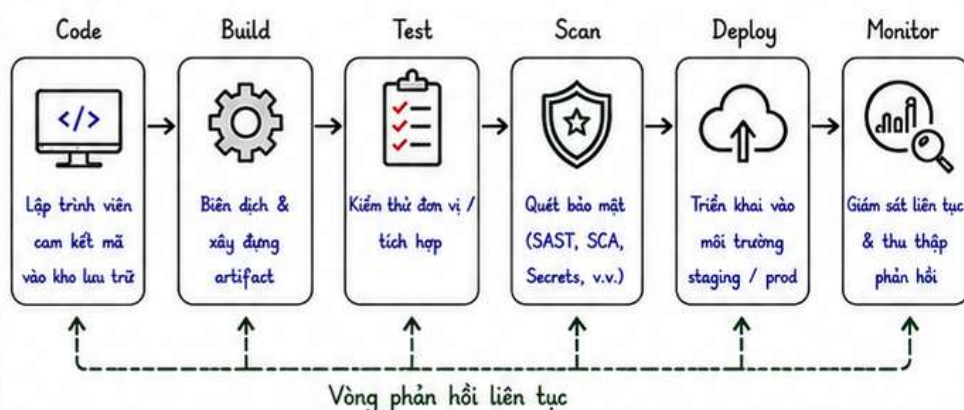
17. DevSecOps & Secure SDLC

DevSecOps tích hợp bảo mật vào DevOps và SDLC để bảo mật được tích hợp sẵn, tự động hóa và diễn ra liên tục trong toàn bộ vòng đời phần mềm.

① Khái niệm chính

- **Secure SDLC:** Bảo mật ở mọi giai đoạn của vòng đời phát triển.
- **Shift Left Security:** Tìm và khắc phục lỗi hỏng càng sớm càng tốt trong SDLC.
- **DevSecOps:** Con người + Quy trình + Công cụ để tự động hóa bảo mật.
- **Mục tiêu:** Cung cấp phần mềm an toàn nhanh hơn với phản hồi liên tục.

② Pipeline CI/CD an toàn



③ Công cụ bảo mật trong Pipeline

- **SAST:** Phân tích mã tĩnh để tìm lỗi hỏng sớm trong mã nguồn.
- **DAST:** Kiểm thử động trên ứng dụng đang chạy để tìm lỗi thời gian chạy.
- **SCA:** Phân tích thành phần phần mềm để phát hiện các thành phần mã nguồn mở dễ bị lỗi.
- **Quét bí mật:** Phát hiện bí mật cứng, khóa API, token trong mã.
- **Kiểm tra phụ thuộc:** Đảm bảo thư viện bên thứ ba luôn được cập nhật và an toàn.
- **Quét container:** Quét image container để tìm các lỗ hỏng đã biết.

④ Các giai đoạn của Secure SDLC

- 1. Yêu cầu**
Xác định yêu cầu bảo mật, đánh giá rủi ro, tuân thủ quy định.
- 2. Thiết kế**
Mô hình mối đe dọa, kiến trúc bảo mật, sơ đồ luồng dữ liệu.
- 3. Phát triển**
Viết mã an toàn, code review, SAST, quét bí mật.
- 4. Kiểm thử**
DAST, SCA, kiểm tra nhập, quét lỗi hỏng.
- 5. Triển khai**
Quét cấu hình bảo mật, quét IaC, kiểm tra container.
- 6. Vận hành**
Giám sát, vá lỗi, ứng phó sự cố, cải tiến liên tục.

⑤ Lợi ích của DevSecOps

- ✓ Phát hiện sớm = chi phí sửa lỗi thấp hơn.
- ✓ Giảm rủi ro bảo mật trong môi trường sản xuất.
- ✓ Bảo mật tự động = kết quả nhất quán.
- ✓ Phát hành nhanh hơn với bảo mật tích hợp.
- ✓ Tuân thủ & sẵn sàng cho kiểm toán tốt hơn.
- ✓ Cải thiện sự hợp tác giữa các nhóm Dev, Sec & Ops.

Ghi nhớ

Bảo mật không phải là một giai đoạn, mà là một quá trình liên tục.
Shift Left = Bảo mật sớm, Bảo mật mãi mãi!

⑥ Thực hành tốt nhất

- ✓ Tự động hóa quét bảo mật trong CI/CD.
- ✓ Sử dụng Infrastructure as Code (IaC) scan.
- ✓ Giữ thư viện phụ thuộc & base image luôn cập nhật.
- ✓ Lưu trữ bí mật trong kho kín, không đưa vào mã.
- ✓ Áp dụng nguyên tắc đặc quyền tối thiểu & cấu hình an toàn.
- ✓ Giám sát liên tục & thu thập chỉ số bảo mật.

⚠ Sai lầm thường gặp

- Chỉ thêm bảo mật ở giai đoạn cuối.
- Bỏ qua kết quả quét bảo mật thất bại.
- Lưu trữ bí mật trong kho mã.
- Sử dụng thư viện bên thứ ba lỗi thời.
- Cấu hình cloud / container sai.

🎯 Mẹo phỏng vấn

Hãy sẵn sàng giải thích:

- ✓ SAST vs DAST vs SCA
- ✓ Khái niệm Shift Left
- ✓ Bảo mật phù hợp như thế nào trong CI/CD
- ✓ Chiến lược quản lý bí mật
- ✓ Bảo mật container & phụ thuộc



Điểm chính cần nhớ

DevSecOps là tích hợp bảo mật vào mọi bước của phát triển và vận hành.

Mã an toàn → Build an toàn → Triển khai an toàn → Vận hành an toàn

18. An ninh mạng nâng cao & Ôn tập nhanh

① Mô hình Zero Trust

Không tin tưởng,
luôn xác thực.

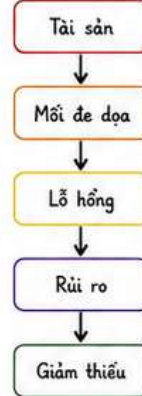
- Xác thực rõ ràng
- Quyền tối thiểu
- Giả định đã bị xâm nhập
- Phân đoạn vi mô
- Giám sát liên tục



② Mô hình đe dọa

Xác định mối đe dọa sớm
ngay từ thiết kế.

- Xác định tài sản
- Xác định mối đe dọa
- Xác định lỗ hổng
- Đánh giá rủi ro
- Lập kế hoạch giảm thiểu
- Xác thực liên tục



③ Phòng thủ đa lớp

Sử dụng nhiều lớp
kiểm soát bảo mật.

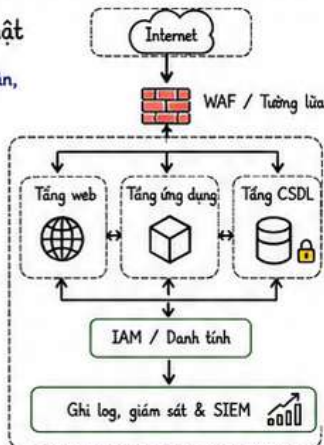


Nếu một lớp bị lỗi,
các lớp khác vẫn bảo vệ.

④ Kiến trúc bảo mật

Xây dựng hệ thống an toàn,
mở rộng và bền vững.

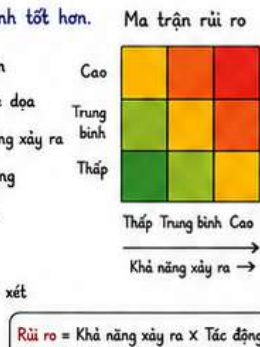
- Bảo mật từ thiết kế
- Phân đoạn hệ thống
- Mã hóa mọi nơi
- Kiểm soát truy cập (IAM)
- Ghi log & giám sát
- Tính sẵn sàng cao



⑤ Quản lý rủi ro

Hiểu rủi ro,
để ra quyết định tốt hơn.

- Xác định tài sản
- Xác định mối đe dọa
- Đánh giá khả năng xảy ra
- Đánh giá tác động
- Tính toán rủi ro
- Xử lý rủi ro
- Giám sát & xem xét



⑥ Tổng quan về MITRE ATT&CK

Khung tham chiếu để hiểu hành vi
của kẻ tấn công.

- Chiến thuật: 14 mục tiêu cấp cao
- Kỹ thuật: 100+ cách thức
- Dùng cho phát hiện, săn tìm
mối đe dọa & phòng thủ



⑦ Lộ trình nghề nghiệp An ninh mạng



⑧ Các khái niệm ôn tập quan trọng

- CIA Triad
- Quyền tối thiểu
- Zero Trust
- OWASP Top 10
- Mã hóa vs Băm
- TLS Handshake
- MFA & IAM
- Bảo mật mạng (FW, IDS/IPS)
- Lỗ hổng vs Khai thác
- CVE, CVSS
- SIEM & SOC
- Các giai đoạn IR
- MITRE ATT&CK
- SAST vs DAST vs SCA
- Trách nhiệm chia sẻ trên Cloud



⑨ Những điểm chính cần ghi nhớ

- ✓ An ninh mạng là quá trình liên tục, không phải làm một lần.
- ✓ Con người, quy trình và công nghệ phải phối hợp với nhau.
- ✓ Ngăn chặn → Phát hiện → Ứng phó → Khôi phục → Cải thiện.
- ✓ Bảo mật là trách nhiệm của tất cả mọi người.
- ✓ Luôn cập nhật, thực hành trong lab và xây kỹ năng thực tế.
- ✓ Nghĩ như kẻ tấn công, phòng thủ như chuyên gia.



Ghi nhớ

Không có hệ thống nào
an toàn 100%,
nhưng bảo mật tốt sẽ giảm
rủi ro và tác động đáng kể.



Sai lầm thường gặp

- ✗ Bỏ qua cập nhật và lỗi
- ✗ Mật khẩu yếu / không MFA
- ✗ Tài khoản đặc quyền quá nhiều
- ✗ Không giám sát hoặc ghi log
- ✗ Không kiểm thử kiểm soát bảo mật



Tóm tắt
thực hành tốt nhất



Triển khai
Zero Trust



Phát hiện
sớm



Ứng phó
chuẩn bị



Khôi phục
nhau chóng



Luôn bảo mật
Luôn học hỏi



 **FOLLOW** 
& COMMENT